

PENETRATION TESTING FUNDAMENTALS

MODULE 4

Social Engineering Attacks

Student Study Guide

Topics: Pretexting & Impersonation · Phishing Attacks · Physical Attacks · Social Engineering Tools · Methods of Influence

1. Pretexting and Impersonation

1.1 Elicitation

Elicitation is the act of gaining knowledge or information from people. In most cases, an attacker gets information from a victim without directly asking for that particular information — the victim reveals it naturally through conversation.



KEY CONCEPT

Social engineering exploits human psychology rather than technical vulnerabilities. The attacker's most powerful weapon is conversation, not code.

1.2 Interrogation Techniques

How an attacker interrogates and interacts with a victim is crucial for the success of a social engineering campaign. Skilled interrogators use a mix of open-ended and closed-ended questions to steer conversations.

Question Type	Purpose	Risk if Overused
Open-ended questions	Learn about the victim's viewpoints, values, goals, and reveal additional information naturally	None — but too many can feel like an interrogation
Closed-ended questions	Control the conversation, lead it in a specific direction, or stop it when needed	Asking too many makes the victim shut down the interaction



NOTE

Successful social engineers use a 'narrowing approach' — starting broad and gradually focusing questions to extract maximum information without raising suspicion.

What Interrogators Observe

Skilled interrogators pay close attention to non-verbal cues in their victims:

- Posture and body language

- Skin colour changes — face becoming pale or red
- Direction of head and eyes
- Movement of hands and feet
- Mouth and lip expressions
- Pitch and rate of voice, including changes
- Words used — length, syllables, dysfunctions, and pauses

1.3 Pretexting

With pretexting (also called impersonation), an attacker presents as someone else to gain access to information or systems. This can range from a simple lie to an elaborate false identity. Social engineers use pretexting to impersonate individuals in specific jobs and roles — even without experience in those roles.

Common Pretexting Scenarios

Delivery Person Impersonation

An attacker impersonates a delivery person from Amazon, UPS, FedEx, or a bicycle courier with an 'urgent message'. This gains physical access to reception areas, lobbies, and sometimes secure areas of an office.

IT Support Worker Impersonation

An attacker poses as IT staff and offers unsolicited help to users. This is extremely effective because almost everyone has a technical problem. Once trusted, the attacker may gain physical access to computers, insert USB drives with malicious scripts, and compromise systems in seconds.

1.4 Pharming

Pharming is a type of impersonation attack where a threat actor redirects a victim from a legitimate website to a malicious one that looks identical. The goal is to steal confidential information or install malware.

Methods of Pharming

- Altering the hosts file on a victim's system

- DNS poisoning (corrupting a DNS cache to point to a malicious IP)
- Exploiting a vulnerability in a DNS server directly

 NOTE

Malvertising is a related attack. It involves incorporating malicious advertisements on trusted, legitimate websites. Users who click these ads are redirected to sites hosting malware — even without the website owner's knowledge.

2. Social Engineering Attacks

Social engineers use a wide variety of attack methods. Understanding each type is essential for both attacking and defending. The following sections cover every major attack type, how they work, and how to recognise them.

2.1 Email Phishing

 Email Phishing

An attacker presents a link or attachment that appears to come from a trusted, legitimate source. When the user clicks it, they are prompted to enter confidential information — such as a username and password — on a fake login page controlled by the attacker.

Element	Description
Target	Broad — sent to large numbers of random recipients
Technique	Fake links, fake attachments, spoofed sender addresses
Goal	Steal credentials, install malware, redirect to fake sites
Example	A fake 'Your account is locked — click here to verify' email from a spoofed bank

2.2 Spear Phishing

 Spear Phishing

Spear phishing is a highly targeted phishing attack aimed at specific individuals or organisations. The attacker studies the victim and their organisation to craft emails that appear legitimate — often appearing to come from trusted colleagues or internal staff.

Element	Description
Target	Specific individuals, teams, or organisations
Technique	Researched, personalised emails that reference real names, projects, or events
Goal	Steal credentials or deliver malware to a specific high-value target
Example	An email appearing to come from the IT department asking a specific employee to reset their VPN password



TIP

Reconnaissance (Module 3) feeds directly into spear phishing. The more an attacker knows about their target — from social media, job listings, and OSINT — the more convincing the spear phishing email will be.

2.3 Whaling



Whaling

Whaling is phishing specifically targeting high-profile business executives and key individuals (CEOs, CFOs, CISOs, board members). Whaling emails and web pages have a more official, serious look and feel — often mimicking critical business communications or legal/regulatory notices.

Element	Description
Target	C-suite executives, board members, and key decision-makers
Technique	Executive-level content — fake legal notices, board meeting materials, urgent financial requests
Goal	Steal sensitive data, compromise executive accounts, then target other high-value victims
Example	A fake SEC compliance notice addressed to the CFO, requesting wire transfer approval

⚠ IMPORTANT

The main goal in whaling attacks is to steal sensitive information or compromise the executive's system, then use that access to target other high-profile individuals in the organisation's network.

2.4 Vishing (Voice Phishing)

📞 Vishing

Vishing (voice phishing) is a social engineering attack conducted over a phone call. The attacker persuades the victim to reveal private personal and financial information, or information about another person or company.

Element	Description
Target	Individuals — often elderly or less tech-savvy victims
Technique	Impersonating banks, government agencies (IRS, HMRC), tech support, or company HR
Goal	Steal credit card numbers, Social Security/National Insurance numbers, bank credentials
Key tool	Caller ID spoofing — attacker masks their real number with a trusted number

2.5 SMS Phishing (Smishing)

📱 SMS Phishing (Smishing)

SMS phishing (also called smishing) uses text messages to send malicious links or malware to mobile devices. Attackers may spoof the identity of legitimate organisations — banks, delivery companies, social media platforms — to trick victims into clicking links.

Real-World Example

Bitcoin-related SMS scams have instructed victims to click links to 'confirm accounts and claim bitcoin'. When users click, they are taken to attacker-controlled sites that harvest sensitive information.

How to Protect Yourself

- Never click links from unknown or unexpected senders

- If you receive a message about a bank or order problem — go directly to the official website, do not click the link
- If you receive a message claiming you won something — it is almost certainly a smishing attempt
- Call organisations directly using their official number to verify any claim

 TIP

Attackers often spoof sender identities to look like Amazon, your bank, or your Internet provider. The message may even contain your name or partial account details gathered from prior data breaches.

2.6 USB Drop Key Attack

 USB Drop Key Attack

A USB drop attack involves leaving infected USB drives in strategic locations — car parks, office lobbies, near reception desks. Curious users pick them up and plug them in, triggering automatic malware installation.

Research by Elie Bursztein (Google's anti-abuse research team) involved dropping approximately 300 USB sticks on a university campus. The results were alarming:

Metric	Result
USB drives picked up	98% of all dropped drives were picked up by someone
Drives plugged in AND files clicked	45% of users not only inserted the drive but also clicked on files

A more advanced version of this attack uses a key ring containing a USB drive, real keys, and photos of children or pets — personalised touches designed to make the victim feel compelled to return it, making them far more likely to plug it in.

 IMPORTANT

Never plug in a USB drive you found anywhere — car parks, office lobbies, street corners. Even a brief insertion can execute malware before you see anything on screen.

2.7 Watering Hole Attack

Watering Hole Attack

A watering hole attack targets websites that the intended victim regularly visits. The attacker scans those websites for vulnerabilities, compromises one, and injects malicious JavaScript or code that redirects visitors to an exploit server. The goal is to infect computers used by members of a target organisation.

Stage	What Happens
1. Profiling	Attacker identifies websites the target organisation's employees frequently visit
2. Scanning	Attacker scans those sites for exploitable vulnerabilities
3. Compromise	Attacker injects JavaScript or exploit code into the vulnerable site
4. Redirect	When victims visit the site, they are silently redirected (pivot attack) to an exploit server
5. Infection	Malware is delivered to victims' machines, giving the attacker a foothold in the network

Defence Against Watering Hole Attacks

- Keep anti-malware applications updated — automatic updates are essential
- Use secure virtual browsers with limited connectivity to the rest of the system
- Administrators: scan your organisation's own website for injected malware regularly
- Apply proper programming methods and input validation to your web applications
- User education and awareness are paramount — users who understand the threat can report unusual website behaviour

3. Physical Social Engineering Attacks

Physical attacks target physical security controls and human behaviour in the real world. These attacks often bypass even the most sophisticated digital defences.

3.1 Tailgating & Piggybacking



Tailgating & Piggybacking

Piggybacking: An unauthorised person follows an authorised person through a secured door — usually with the authorised person's consent (they hold the door out of politeness). **Tailgating:** Essentially the same, but it occurs without the authorised person's knowledge or consent.

Countermeasures

Control	How It Helps
Access Control Vestibule (Mantrap)	A small enclosed space with two doors — the first must close before the second opens. Creates a waiting room where identity is verified. Cannot be bypassed by tailgating. Commonly used in data centres and server rooms.
Multifactor Authentication at Entry	A proximity card + PIN at the first door and a biometric scan at the second makes it nearly impossible to piggyback.
Turnstiles & Double Entry Doors	Less expensive and less secure than vestibules but still effective at reducing tailgating.
Security Guards	Human monitoring at entry points can identify unauthorised persons attempting to follow.



TIP

An access control vestibule is a preventive security control. Even with all the best digital controls in place, physical access can give an attacker everything they need.

3.2 Dumpster Diving



Dumpster Diving

Dumpster diving involves scavenging through an organisation's garbage and recycling containers to find sensitive information. Discarded documents, old hard drives, removable media, and printed spreadsheets are all valuable to attackers.

What Attackers Look For

- Printed documents containing financial data, passwords, or PII
- Old hard drives or removable storage media
- Organisational charts, employee contact lists
- Printed emails or memos revealing internal processes or systems

How to Prevent Dumpster Diving

- Store sensitive documents securely for as long as required by policy
- Shred all sensitive paper documents before disposal — use cross-cut shredders
- Consider incineration or certified third-party shredding for highly sensitive materials
- Degauss or physically destroy hard drives before disposal — do not simply delete files

3.3 Shoulder Surfing

Shoulder Surfing

Shoulder surfing is the act of obtaining sensitive information — PII, passwords, PINs, confidential data — by directly observing a victim using a device. This can be done in person by looking over someone's shoulder, or remotely using binoculars, a telescope, or small hidden cameras and microphones.

Method	Detail
Direct observation	Physically standing close enough to read a screen or keyboard in a public place or open office
Remote observation	Using binoculars, telescopes, or long-range cameras in crowded locations such as airports, cafes, or open-plan offices
Hidden cameras/microphones	Small covert recording devices placed near ATMs, kiosks, or workstations

Prevention

- User awareness and training — know your surroundings when entering sensitive data
- Use screen privacy filters (polarised films that prevent viewing at an angle)
- Position screens away from windows and public areas
- Shield PIN pads and keyboards when entering credentials

3.4 Badge Cloning

Badge Cloning

Badge cloning involves duplicating an access badge or card to gain physical entry to a building or restricted area. Specialised software and hardware can clone RFID/NFC-based access cards.

Attackers may also simply create a convincing-looking fake badge — particularly if they have obtained images of real badges from social media.

 WATCH OUT

Attackers obtain detailed information about corporate badge designs from social media — photos of new employees proudly showing their badge after their first day, or departing employees posting 'last day' photos. Never post photos of access badges online.

Attack Vectors

- RFID cloning: specialised readers capture card data; a blank card is then written with the cloned data
- Social engineering: attacker convinces other users to let them in using a fake-looking badge
- Tailgating after cloning: even a partial clone can be enough to look convincing during a tailgate attempt

4. Social Engineering Tools

Penetration testers and attackers have access to powerful tools that automate and streamline social engineering attacks. As a security professional, understanding these tools is essential for both offensive testing and building effective defences.

4.1 Social-Engineer Toolkit (SET)

The Social-Engineer Toolkit (SET) was developed by David Kennedy and is one of the most widely used frameworks for social engineering attacks. It integrates with third-party tools and frameworks including Metasploit.

Feature	Detail
Developer	David Kennedy (TrustedSec)
Platform	Pre-installed on Kali Linux and Parrot Security. Also available for other Linux distributions and macOS.

Capabilities	Launch numerous social engineering attacks, phishing campaigns, credential harvesting, and more
Integration	Can be integrated with Metasploit for post-exploitation capabilities
Download	github.com/trustedsec/social-engineer-toolkit

4.2 Browser Exploitation Framework (BeEF)

BeEF is a tool that manipulates users by exploiting cross-site scripting (XSS) vulnerabilities in web applications. XSS vulnerabilities leverage input validation weaknesses to redirect users to malicious websites and steal cookies (session tokens) and other sensitive information.

Feature	Detail
Attack vector	Cross-site scripting (XSS) vulnerabilities in web applications
Capabilities	Hook victim browsers, steal session cookies, redirect to phishing pages, run browser-based attacks
Use case	Module 6 (Web Application Vulnerabilities) covers XSS and CSRF in depth
Download	beefproject.com github.com/beefproject/beef

 NOTE

XSS vulnerabilities are covered in detail in Module 6: Exploiting Application-Based Vulnerabilities. Understanding XSS is essential to understanding how BeEF works.

4.3 Call Spoofing Tools

Caller ID information displayed on a phone can be changed very easily. Call spoofing tools are commonly used in vishing attacks to impersonate trusted organisations or individuals.

Tool	Platform	Capabilities
SpoofApp	iOS & Android	Easily spoof any phone number to display a different caller ID

SpoofCard	iOS & Android	Spoof caller ID, change voice, record calls, generate background noise, send straight to voicemail
Asterisk	VoIP platform (any)	A legitimate VoIP management tool that can be configured to impersonate any caller ID — widely used in enterprise and red team engagements

5. Methods of Influence

Social engineers exploit predictable patterns of human psychology. Understanding these influence techniques is essential to recognising when you or your colleagues are being manipulated — and to designing effective security awareness training.

KEY CONCEPT

These psychological triggers are used in combination. A skilled social engineer might use authority to establish credibility, urgency to prevent careful thinking, and social proof to normalise the request — all in the same message.

5.1 Authority

Authority

A social engineer presents themselves with confidence and authority — whether legal authority (police, government), organisational authority (CEO, IT department), or social authority (expert, doctor). People are conditioned to comply with authority figures, making this one of the most effective triggers.

- "This is the IT security team — we need your password to resolve a critical issue."
- "This is Detective [Name] from the fraud unit — you need to transfer funds immediately."
- "This is the CEO — I need this wire transfer processed right now."

5.2 Scarcity and Urgency

Scarcity and Urgency

Scarcity creates a feeling of urgency that short-circuits rational decision-making. When people believe time is running out or supply is limited, they act quickly without stopping to verify. Social engineers use specific language to heighten urgency and manipulate victims into acting before thinking.

- "This offer expires in 10 minutes — click now."
- "Your account will be permanently suspended in 24 hours unless you verify immediately."
- "There are only 2 spots left — you must register now."

NOTE

Sales tactics ("offer only valid today", "limited supply") and social engineering tactics are identical in structure. Both exploit the fear of missing out (FOMO) to bypass careful evaluation.

5.3 Social Proof

Social Proof

Social proof is a psychological phenomenon where individuals look to others' behaviour to determine correct action in unfamiliar situations. When people are uncertain, they assume that what others are doing must be appropriate. Social engineers exploit this by creating the illusion of group consensus or normalcy.

- "Everyone in your department has already completed this update — you are the last one."
- "All your colleagues submitted their credentials through this portal last week."
- Fake review systems, fake follower counts, and fake social media engagement all exploit social proof

5.4 Likeness (Liking)

Likeness

People are more easily influenced by those they like. Social engineers invest significant effort in making themselves likable — mirroring the victim's behaviour and language, complimenting them, finding common ground, and showing genuine interest. Most people also like to be appreciated and enjoy talking about themselves, which social engineers exploit through conversation.

- Mirroring: copying the victim's posture, speech patterns, and interests
- Complimenting the victim's expertise or work to build rapport

- Referencing shared connections: "I know [colleague name] — they said you were the right person to speak to"
- Appearing aesthetically pleasing and professionally presented

5.5 Fear

Fear

Fear is one of the most powerful motivators. By creating a belief that something bad or dangerous is about to happen, social engineers force victims to act quickly without thinking — to avoid or rectify a feared situation. The faster the victim acts, the less likely they are to question the legitimacy of the request.

- "Your computer has been infected with a virus — call this number immediately." (Tech support scam)
- "You owe unpaid taxes — law enforcement will arrest you in 2 hours unless you pay now." (Government impersonation)
- "We have detected unauthorised access to your bank account — verify now or it will be frozen."

IMPORTANT

Fear-based attacks create a state of panic that overrides rational thinking. Training employees to pause, breathe, and verify independently — never through links or numbers provided in the scary message — is the key defence.

6. Attack Type Quick Reference

Use this table to quickly compare all the social engineering attacks covered in this module.

Attack	Medium	Target	Primary Goal
Email Phishing	Email	Anyone	Steal credentials / deliver malware

Spear Phishing	Email	Specific individuals/orgs	Targeted credential theft or malware
Whaling	Email/Web	C-suite executives	Steal sensitive data / compromise exec accounts
Vishing	Phone call	Individuals	Steal financial / personal info
SMS Phishing (Smishing)	Text message	Mobile device users	Click malicious link / install malware
USB Drop	Physical	Office workers	Deliver malware via physical media
Watering Hole	Web	Organisation employees	Infect visitor devices / gain network foothold
Tailgating/Piggybacking	Physical	Anyone at secure entry	Gain unauthorised physical access
Dumpster Diving	Physical	Organisation as a whole	Find sensitive discarded information
Shoulder Surfing	Physical	Device users in public	Observe credentials or sensitive data
Badge Cloning	Physical/RFID	Building access systems	Clone access credentials for physical entry
Pharming	DNS/Hosts file	Web users	Redirect to malicious site / steal credentials

7. Module Summary & Key Takeaways

 REMEMBER

Social engineering is the art of manipulating people rather than systems. Even the most technically secure organisation can be breached through its people. Security awareness training is a critical, ongoing countermeasure — not a one-time exercise.

Key Takeaways

1. Elicitation is the foundation of social engineering — attackers gain information through conversation, not code.
2. Pretexting and impersonation allow attackers to assume false identities to gain access to information or systems.
3. Phishing attacks come in multiple forms: email phishing, spear phishing, whaling, vishing, and smishing — each more targeted than the last.
4. Physical attacks (tailgating, dumpster diving, shoulder surfing, badge cloning) bypass digital controls entirely.
5. USB drop attacks are devastatingly effective — 98% of dropped drives are picked up and 45% result in file access.
6. Watering hole attacks compromise trusted websites to infect targeted visitors — even without any direct attack on the victim.
7. SET, BeEF, and call spoofing tools give attackers and pentesters powerful, automated social engineering capabilities.
8. Social engineers exploit five core psychological triggers: Authority, Scarcity/Urgency, Social Proof, Likeness, and Fear.
9. The best defence is a layered approach: technical controls + physical security + continuous user awareness training.

The Five Methods of Influence — Summary

Trigger	How It's Exploited	Key Defence
Authority	Impersonating figures of power to demand compliance	Verify identity independently — never through contact info provided in the message
Scarcity/Urgency	Creating time pressure to prevent rational evaluation	Pause. Verify. Never act purely because of a deadline in a suspicious message

Social Proof	Creating illusion of group consensus or normalised action	Question the claim — verify with colleagues directly, not through the message
Likeness	Building rapport and trust before making the attack	Treat unsolicited contact with professional scepticism regardless of how friendly it seems
Fear	Triggering panic to force immediate, thoughtless action	Pause and breathe. Verify via official channels — not links or numbers in the message

End of Module 4
